GUION DE LECTURA Y DEMOSTRACION

HotelSec PolicyForge AI

Practica 3 - Pablo Cortes

Version 0.4.0 | 13/10/2026

17-20 minutos orientativos; medir el MP4 real

Texto literal + acciones de pantalla + respuestas alternativas.

No leer las instrucciones ni todas las alternativas. Ensayar antes; explicar con tus palabras si el docente pregunta. No se han grabado video ni minutos reales.

https://178-105-149-202.sslip.io/

Lo que exige el enunciado

- MP4 de al menos 10 minutos. El enunciado recomienda no superar 20, aunque no fija un máximo estricto.

- Resolución mínima 720p; recomendada 1080p. La pantalla debe leerse y el audio oírse con claridad.

- Presentación, requisitos originales y cambios, arquitectura, recorrido funcional, errores/seguridad y limitaciones.

- Mostrar el producto real obtenido del código entregado. Las diapositivas son solo apoyo; la mayoría del vídeo debe mostrar la app.

- Los cortes para eliminar esperas deben identificarse en pantalla. No cortar para ocultar fallos.

- Datos ficticios y sistemas propios. No grabar contraseñas, claves, cookies, archivos .env ni credenciales del VPS.

- Subir a YouTube no listado o servicio equivalente con permiso para cualquiera con el enlace. Probar en incógnito.

- Después de grabar, anotar los minutos exactos de cada requisito y poner el enlace en portada y comentario de entrega. Los tiempos de este guion NO son esa evidencia.

Fuente: enunciado Practica_3_Evolve (1).pdf, paginas6-8 y11-12, proporcionado por el alumno. No es necesario comprar un dominio ni una webcam.

Antes de pulsar REC

1. Ensaya una vez. Lee solo los párrafos LEER y realiza las acciones de PANTALLA sin pronunciarlas. Usa el guion en otro dispositivo/monitor que no estés capturando.

2. Entiende antes sesiones, CSRF, propietario, scoring, snapshots y fallback. El enunciado permite asistencia IA, pero exige comprender lo entregado.

3. Abre la app pública, el repo en la rama practica3, VS Code con este proyecto, la memoria previa al vídeo y una ventana de incógnito.

4. En VS Code deja abiertas solo README.md, docker-compose.production.yml, backend/app/db.py y docs/practica3/evidence/closeout-verification.json. No abras .env, inspect ni configuración efectiva con secretos.

5. Crea una cuenta NUEVA de vídeo para empezar con historial vacío. Correo ficticio sugerido: video-pablo-1310-01@example.org. Si ya la usaste en el ensayo, usa otro sufijo, por ejemplo02. Elige una contraseña privada y única de12-128 caracteres; no hay contraseña compartida en este guion.

6. Guarda esa contraseña de forma privada para poder iniciar sesión, exportar datos y borrar la cuenta de demo al terminar. No actives el icono de mostrar contraseña.

7. Comprueba que backend/.venv/Scripts/python.exe existe antes de mostrar los comandos del anexo. Ejecútalos desde la raíz del proyecto en PowerShell. No son comandos del SSH de Hetzner.

8. El bloque IA es opcional en este recorrido y puede consumir crédito: una petición puede hacer hasta tres llamadas. Esta preparación no ejecuta llamadas de pago. Si no quieres gastar, usa la alternativa expresamente sin nueva prueba IA.

9. Si muestras IA real, usa el texto coherente del caso mejorado. No vuelvas a enviar una contradicción con IA una y otra vez: podría gastar cuota/crédito.

10. Cierra correo, notificaciones, pestañas personales y gestores de contraseñas. Graba 15 segundos de prueba de audio y pantalla antes de empezar.

11. El grupo sigue sin confirmar. Añade el número real a tu presentación cuando lo sepas; no digas grupo01 ni inventes compañeros. El guion base identifica correctamente tu trabajo individual.

12. La instalación por una persona externa aún está pendiente. Si no se ha hecho al grabar, usa la frase de limitación incluida, no una afirmación de éxito.

Ficha del hotel ficticio

Campo	Valor
Nombre del alojamiento	Hotel Demo Lanzarote - Video
Municipio / Tipo	Tías / Hotel
Habitaciones / fijos / temporales	40 / 12 / 8
Frecuencia de backups inicial	No se realizan
Temporada alta / Respuesta IT	Todo el año / 24 horas
Sistemas	PMS en la nube, Microsoft 365, TPV
Categorías de datos	Reservas, facturación
Conservación prevista	180 días ficticios; no es una recomendación legal ni el borrado de la app
Gobierno y continuidad	Plan de continuidad: No. Resto: Sin confirmar
Contexto inicial	No usamos MFA y no hacemos copias.
Permiso de OpenAI al inicio	Desmarcado
Mejora posterior	MFA y gestor: Sí; backups: Diaria; restauración, actualización y WiFi separada: Sí
Texto para nueva prueba IA, si decides hacerla	El correo del hotel usa doble factor. Las copias de seguridad se realizan a diario y se prueba su restauración.

Estas cifras son datos ficticios, no resultados calculados ni recomendaciones legales.

Casillas del primer analisis

MARCADAS

- Proveedor IT externo
- Usa PMS o channel manager
- Ofrece WiFi a huéspedes
- Acepta pagos con tarjeta
- Usa doble factor (marcado intencionadamente para la contradicción)
- Comparte cuentas
- Tiene antivirus/EDR
- Usa cámaras, domótica o IoT
- Proveedores con acceso remoto

DESMARCADAS

- Guarda documentación de huéspedes
- Usa gestor de contraseñas
- PMS con usuarios individuales
- Proceso de baja de empleados
- Prueba restauración de backups
- Sistemas actualizados
- WiFi de huéspedes separada
- TPV/red de pagos aislada
- IoT/CCTV en red separada
- Acceso remoto de proveedores controlado
- Plan de respuesta a incidentes
- Protocolo de brechas RGPD
- Registro RGPD de tratamientos
- Formación contra phishing

B01 | 00:00-00:50 PREVISTO

Presentación

Requisitos: RE-01, RE-02

PANTALLA - NO LEER

- Mostrar la app en la pantalla de acceso, sin escribir contraseñas todavía.
- Si conoces tu grupo al grabar, añadir su número real tras decir tu nombre.

LEER

Hola, soy Pablo Cortes y presento HotelSec PolicyForge AI para la Práctica 3 de Evolve Academy. Realizo este proyecto de forma individual. Es una herramienta de autodiagnóstico de ciberseguridad dirigida a hoteles y alojamientos turísticos de Lanzarote.

El problema que quiero resolver es que una pequeña empresa puede saber que tiene riesgos, pero no cómo organizarlos ni por dónde empezar. La aplicación transforma sus respuestas en una evaluación de madurez, riesgos priorizados, políticas propuestas y un plan de mejora.

Voy a mostrar el producto real funcionando, desde la creación de una cuenta hasta la descarga del informe, incluyendo validaciones, controles de acceso y limitaciones. Todos los datos del hotel que utilizaré son ficticios.

B02 | 00:50-01:40 PREVISTO

Punto de partida y requisitos

Requisitos: RE-01, RE-03

PANTALLA - NO LEER

- Mostrar el repositorio GitHub, rama practica3, y brevemente docs/practica3/06_estado_entrega.md.
- Volver a la app antes de entrar en explicaciones largas.

LEER

Este producto continúa la Práctica 1, que obtuvo un nueve sobre diez. El profesor no dejó comentarios, así que no le atribuyo recomendaciones que no recibí. La revisión se hizo sobre el código y los compromisos originales.

El prototipo inicial necesitaba completar la persistencia, la autenticación, el historial, el seguimiento de acciones y el informe PDF. También era necesario integrar mejor el texto libre con las respuestas del formulario y resolver las contradicciones.

La matriz relaciona cada requisito con su implementación y sus pruebas. El vídeo que estoy grabando permitirá añadir después los minutos reales de evidencia. No se han usado los tiempos previstos del guion como si fueran una grabación ya realizada.

B03 | 01:40-03:00 PREVISTO

Arquitectura y decisiones

Requisitos: RNF-01, RNF-03, RNF-07, RE-03

PANTALLA - NO LEER

- Mostrar el diagrama de la página7 de la memoria actual, si mantiene esa página, o localizar Separación de responsabilidades en su índice.

- En VS Code señalar frontend/src, backend/app, backend/migrations y docker-compose.production.yml.

- Mostrar https://178-105-149-202.sslip.io/api/v1/health y comprobar 0.4.0 / production. No abrir archivos privados.

LEER

La arquitectura separa la pantalla, la lógica de negocio y los datos. El frontend utiliza React, TypeScript y Vite. Su función es recoger las respuestas y presentar los resultados.

El backend utiliza FastAPI y Pydantic para validar las peticiones. SQLAlchemy accede a PostgreSQL y Alembic aplica los cambios de esquema de forma versionada. La puntuación se calcula mediante reglas, y OpenAI es una integración opcional para interpretar contexto y personalizar textos. ReportLab genera los informes PDF en el servidor.

Docker Compose organiza los servicios. En Hetzner, Caddy publica la aplicación con HTTPS y la API y la base de datos quedan en la red interna. Esta consulta de salud permite comprobar la versión y el entorno que responde ahora.

Todo el código está en GitHub y es editable. Mantengo la dirección de sslip.io para la práctica, sin comprar un dominio. Es una dependencia externa, no un dominio propio ni una garantía de disponibilidad.

B04 | 03:00-03:50 PREVISTO

Registro y privacidad

Requisitos: RF-11, RNF-05

PANTALLA - NO LEER

- Pulsar Crear cuenta. Nombre: Pablo Demo. Introducir el correo ficticio y tu contraseña privada, siempre oculta.

- Pulsar el botón Crear cuenta del formulario y esperar al Dashboard.

- Si ensayaste con esa cuenta, entrar por Acceder; no fingir que es un registro nuevo.

LEER

Empiezo por el acceso. Cada cuenta tendrá sus propios alojamientos y análisis; no se trata de un panel compartido donde todos puedan ver la misma información.

Utilizo una cuenta de demostración y una contraseña que no voy a mostrar. La aplicación exige una longitud mínima y guarda un hash Argon2, no la contraseña en texto plano. La sesión se identifica mediante una cookie HttpOnly y puede revocarse.

El aviso recuerda que no hacen falta nombres de huéspedes, documentos de identidad ni datos de pago. Para evaluar riesgos basta describir los sistemas y las categorías de información que se utilizan.

B05 | 03:50-05:10 PREVISTO

Formulario del hotel ficticio

Requisitos: RF-01, RNF-02, RNF-05

PANTALLA - NO LEER

- Abrir Nuevo analisis. Rellenar la ficha del hotel y las casillas según la hoja de datos al principio del guion.

- Dejar Usa doble factor marcado deliberadamente. No autorizar OpenAI aún.

- Antes de analizar: poner Habitaciones en0 y pulsar Analizar y guardar para mostrar la validación del navegador. Restablecer40. No decir que esta prueba sola valida el backend.

- Escribir exactamente: No usamos MFA y no hacemos copias.

LEER

Ahora demuestro la recogida del perfil y de los controles del hotel. El ejemplo tiene cuarenta habitaciones, doce empleados fijos y ocho temporales. Declaro que utiliza un PMS, WiFi para huéspedes, pagos con tarjeta y un proveedor informático.

El formulario también recoge temporada, inventario tecnológico, categorías de datos y continuidad. Cuando no conozco una medida, los controles ampliados permiten dejarla sin confirmar; no la presento como verificada.

Voy a introducir cero habitaciones para mostrar una entrada incorrecta. El navegador impide continuar; después lo devuelvo a cuarenta. Además de esta ayuda de interfaz, el servidor valida sus propios límites, como comprueban las pruebas negativas.

Dejo marcada la casilla de doble factor y escribo un texto que lo niega. Lo hago intencionadamente para comprobar que el sistema detecta información contradictoria. Por ahora no autorizo el envío a OpenAI.

B06 | 05:10-06:00 PREVISTO

Contradicción y análisis único

Requisitos: RF-12, RNF-02

PANTALLA - NO LEER

- Pulsar Analizar y guardar. Esperar al diálogo Datos contradictorios.

- Señalar uses_mfa: formulario true, texto false. No hace falta leer el identificador en inglés.

- Pulsar Usar texto. Esperar al Dashboard. Si no aparece el diálogo, revisar la casilla MFA y el texto: no leer una confirmación ficticia.

LEER

La aplicación encuentra la contradicción: en el formulario he indicado doble factor, pero el texto dice que no se utiliza. En lugar de ocultar el conflicto, solicita que decida qué información conservar.

En esta demostración elijo usar el texto. El resto de las respuestas del hotel se mantiene. Esta es una mejora importante: la descripción no produce un informe independiente, sino que complementa el mismo análisis.

Sin autorización de IA, este caso utiliza patrones locales limitados. No voy a presentar esa extracción por reglas como una llamada a OpenAI. El objetivo que compruebo aquí es la combinación de datos y la resolución explícita del conflicto.

B07 | 06:00-06:55 PREVISTO

Dashboard, madurez y riesgos

Requisitos: RF-02, RF-03, RF-07

PANTALLA - NO LEER

- Mostrar Madurez, Riesgos, Acciones completadas y Analisis guardados.

- Bajar a puntuaciones por área y señalar un riesgo relacionado con copias o accesos.

- Mostrar el distintivo Fallback reglas. No leer una puntuación preescrita: los números reales son los de pantalla.

LEER

El dashboard resume la madurez global, los riesgos, las acciones completadas y los análisis guardados. Debajo puedo revisar las áreas de seguridad y las recomendaciones concretas.

Las carencias declaradas, como no realizar copias o no usar doble factor, generan riesgos y prioridades. Cada hallazgo incluye probabilidad e impacto orientativos. No son estadísticas de incidentes ni una medición económica del hotel.

La puntuación se obtiene mediante reglas reproducibles, no mediante una opinión libre de la IA. Tampoco equivale a una auditoría técnica: el sistema evalúa lo que declara el usuario, no comprueba la configuración real de sus equipos.

El resumen aparece identificado como respaldo por reglas, de forma coherente con la opción de no enviar información a OpenAI.

B08 | 06:55-07:45 PREVISTO

Políticas y orientación normativa

Requisitos: RF-04, RF-05

PANTALLA - NO LEER

- Abrir Politicas y mostrar Orden de implantacion.
- Recorrer dos políticas: contraseñas/accesos y copias. Mostrar objetivo, alcance, controles y revisión.
- No afirmar que se usan políticas IA en este análisis por reglas.

LEER

El pack propone diez políticas adaptadas al ámbito hotelero. Incluye accesos y contraseñas, copias, dispositivos, redes, proveedores, incidentes y protección de datos, teletrabajo, correo, PMS y continuidad.

No se limita a un título: cada política presenta un objetivo, un alcance, controles y revisión. El informe incorpora también las evidencias que se podrían solicitar para comprobar su implantación. En este análisis el pack procede de reglas; la personalización con IA se trata por separado.

La herramienta ofrece referencias de AEPD, INCIBE e ISO como orientación. No garantiza cumplimiento del RGPD ni emite una certificación ISO. Las propuestas necesitan revisión humana y adaptación al contexto real de cada alojamiento.

B09 | 07:45-08:40 PREVISTO

Plan de mejora y persistencia

Requisitos: RF-06, RF-07, RF-09

PANTALLA - NO LEER

- Abrir Plan de mejora. Cambiar solo la primera acción a Completada y esperar a que se guarde.
- Recargar con F5. Abrir Historial, localizar este análisis y usar el icono del ojo para abrirlo.
- Volver a Plan de mejora y comprobar que esa acción sigue Completada. No borrar esta evaluación.

LEER

El plan convierte los riesgos en acciones con prioridad, plazo, dificultad y responsable sugerido. Las medidas críticas son inmediatas y las demás se organizan en plazos de treinta o noventa días.

Cambio una acción a completada y recargo la página. Después abro el mismo análisis desde el historial y compruebo que el estado se conserva. Con esto demuestro que el progreso no vive únicamente en la memoria del navegador.

Marcar una acción no aumenta automáticamente la puntuación de seguridad. El estado de trabajo y la evaluación son datos separados: para reflejar medidas nuevas hay que volver a evaluar las respuestas. Esto evita mejorar la nota simplemente pulsando un selector.

B10 | 08:40-10:10 PREVISTO

Historial y reevaluación

Requisitos: RF-09, RF-10, RF-02

PANTALLA - NO LEER

- Con el análisis inicial abierto, ir a Informe y pulsar Reevaluar alojamiento.

- IMPORTANTE: vaciar Contexto adicional para que no siga negando MFA y copias. Mantener el mismo nombre y municipio.

- Marcar MFA, gestor de contraseñas, restauración de backups, sistemas actualizados y WiFi separada. Cambiar Frecuencia de backups a Diaria. Mantener OpenAI desmarcado.

- Analizar y guardar. Comprobar variación de madurez y dos registros en Historial.

LEER

Ahora simulo una mejora del mismo hotel. Abro la reevaluación, mantengo su identidad y cambio varios controles: doble factor, gestor de contraseñas, copias diarias, restauración, actualizaciones y separación del WiFi.

Elimino el texto anterior porque describía una situación distinta. No tendría sentido conservar una descripción que sigue negando las medidas que acabo de introducir.

Al guardar se crea otra evaluación, sin sobrescribir la anterior. En el dashboard puedo ver la variación respecto a la evaluación previa del mismo alojamiento, y en el historial quedan las dos versiones.

La comparación tiene un límite declarado: utiliza los registros de la página cargada, no una consulta analítica de todo el histórico. En este ejemplo, con dos evaluaciones de una cuenta nueva, ambas están disponibles. La mejora refleja nuevas declaraciones, no una comprobación técnica del hotel.

B11 | 10:10-11:00 PREVISTO

Informe PDF para el cliente

Requisitos: RF-08, RF-05, RF-06

PANTALLA - NO LEER

- En Historial abrir la evaluación MÁS ANTIGUA de este hotel, la que contiene la acción completada.

- Abrir Informe y pulsar Descargar informe PDF. Abrir el PDF descargado.

- Mostrar portada/resumen, perfil, riesgos, Plan de accion con Estado: Completada, políticas completas y referencias. Usar búsqueda del visor si es necesario.

LEER

Vuelvo a la evaluación inicial para descargar su informe con el estado de la acción que he completado. El documento es un PDF pensado para revisar y compartir, no una respuesta JSON destinada al desarrollo.

Incluye perfil y respuestas, resumen, puntuaciones, riesgos, plan con estados, políticas completas, fuentes y contexto. Se genera desde la evaluación guardada y los estados actuales, de manera que el contenido es coherente con ese registro.

La descarga exige acceso al análisis propio. El informe también deja claros los límites del autodiagnóstico y el origen del resumen y de las políticas. No es un certificado ni sustituye una revisión profesional.

B12 | 11:00-12:30 PREVISTO

IA real o alternativa honesta

Requisitos: RF-04, RF-12, RF-13, RNF-06

PANTALLA - NO LEER

- Si decides consumir crédito: abrir la evaluación más reciente/mejorada y pulsar Reevaluar alojamiento.

- Pegar el texto coherente de la ficha: El correo del hotel usa doble factor. Las copias de seguridad se realizan a diario y se prueba su restauración.

- Mantener las respuestas mejoradas. Marcar autorización OpenAI UNA vez y guardar. Esperar; si recortas la espera, indicarlo en pantalla.

- Leer SOLO la variante que corresponda al resultado. Si hay IA parcial, no afirmar éxito de todas las etapas.

- Para comprobar origen de políticas por separado, descargar el PDF de ESTA evaluación y mirar Resumen / Politicas en la primera página. El distintivo del dashboard solo acredita el resumen.

LEER

La inteligencia artificial es opcional. Puede interpretar hechos del texto y personalizar las políticas y el resumen, mientras la puntuación sigue calculándose por reglas. El objetivo es complementar el formulario, no sustituirlo ni analizar únicamente la descripción.

Una llamada completa puede consumir crédito y realizar hasta tres peticiones al proveedor. El contador limita veinte peticiones por cuenta y hora UTC y cincuenta globales por día UTC. Estos límites no son un presupuesto monetario duro.

LEER solo si el resumen actual muestra modelo IA y generated_by_ai efectivo, no Fallback reglas

En esta ejecución el resumen aparece identificado con el modelo, no como respaldo por reglas. Las respuestas estructuradas del hotel se mantienen y el texto complementa los controles descritos. El origen de las políticas se comprueba por separado en el PDF: que el resumen use IA no demuestra por sí solo que todas las etapas hayan respondido con IA. Incluso con proveedor correcto, el contenido necesita revisión humana.

LEER si se intentó IA pero aparece Fallback reglas

En esta ejecución aparece el respaldo por reglas, así que no voy a presentarla como una prueba de IA exitosa. El análisis sigue disponible y el origen queda indicado. La evidencia del trece de octubre conserva una prueba anterior autorizada con OpenAI real en extracción, políticas y resumen; esa evidencia es histórica y no sustituye lo que acaba de ocurrir en esta grabación.

LEER si eliges NO hacer una nueva llamada de pago; no marcar la casilla

En esta grabación no voy a realizar una nueva llamada de pago. Muestro la integración y su autorización, pero el resultado actual continúa siendo por reglas. En la carpeta de evidencias hay una prueba real autorizada del trece de octubre, correspondiente a la versión cero punto tres, con extracción, políticas y resumen correctos. La distingo expresamente de una prueba en directo y de los mocks unitarios.

B13 | 12:30-13:45 PREVISTO

Mi cuenta y gestión de datos

Requisitos: RF-11, RNF-05

PANTALLA - NO LEER

- Volver a la app y abrir Mi cuenta > Perfil. Nombre: Pablo Demo. Organización: Hotel Demo Lanzarote. Cargo: Responsable IT. Guardar y recargar; comprobar persistencia.

- Abrir Seguridad para mostrar cambiar contraseña y sesiones, sin escribir ni revelar una contraseña nueva durante este recorrido básico.

- Abrir Actividad. Después Mis datos: introducir la contraseña siempre oculta y pulsar Descargar mis datos. No borrar la cuenta aún.

- Mostrar brevemente que verificar/cambiar correo está desactivado por falta de SMTP.

LEER

Mi cuenta incorpora autogestión del perfil. Puedo cambiar nombre, organización y cargo, guardar y comprobar que persiste al recargar. Esto no modifica las evaluaciones históricas del hotel.

La pestaña de seguridad permite cambiar la contraseña y revisar sesiones. El cambio exige la contraseña actual, revoca sesiones anteriores y emite una nueva para el navegador actual. No voy a mostrar credenciales en la grabación.

En actividad aparecen eventos propios y en Mis datos puedo descargar una copia mediante reautenticación. Esta exportación es JSON para portabilidad; no sustituye al informe PDF del cliente. El borrado requiere contraseña y confirmación reforzada.

El cambio y la recuperación de correo están preparados, pero desactivados porque no hay un proveedor SMTP configurado. No voy a simular que se ha enviado un email.

B14 | 13:45-15:20 PREVISTO

Errores y controles de acceso en acción

Requisitos: RF-11, RNF-02, RNF-03, RNF-05

PANTALLA - NO LEER

- Abrir ventana de incógnito SIN iniciar sesión y visitar https://178-105-149-202.sslip.io/api/v1/records. Mostrar la respuesta Inicia sesion para continuar. No muestra los registros de tu ventana normal.

- En VS Code > Terminal > PowerShell, desde la raíz del proyecto, ejecutar el comando Seguridad en directo del anexo UNA vez.

- Esperar el JSON real. Leer la confirmación SOLO si passed es true y cleanup contiene dos account_deleted. Si no, usar la frase de incidente y explicar el resultado.

- El script usa dos cuentas TEMPORALES nuevas y sin IA; no borra tu cuenta del vídeo ni sus análisis. No abrir logs o archivos de cookies para demostrarlo.

LEER

Ahora compruebo acceso y errores en funcionamiento. En una ventana privada sin sesión intento consultar los registros. La API solicita iniciar sesión y no entrega el historial de mi cuenta.

A continuación ejecuto una comprobación contra mi propia instancia. El script crea dos cuentas ficticias temporales y no utiliza IA. Comprueba cookies, rechazo de una modificación sin CSRF, persistencia tras volver a entrar, PDF y separación entre propietarios.

La segunda cuenta intenta leer, descargar, modificar y borrar un análisis que no le pertenece. Esas operaciones deben rechazarse aunque conozca el identificador. La protección se aplica en el backend, no solo ocultando botones de la pantalla.

Este recorrido no es un ataque a hoteles ajenos ni un pentest completo. Comprueba casos concretos sobre mi aplicación y limpia exclusivamente sus cuentas temporales.

LEER solo con passed true y dos account_deleted

La comprobación termina correctamente y confirma la limpieza de las dos cuentas temporales. Son resultados obtenidos en esta ejecución, distintos de las evidencias guardadas que enseñaré a continuación.

LEER si la comprobación no termina correctamente

Esta comprobación no ha terminado con el resultado esperado. Mantengo el error visible y no voy a declararla superada. El resultado debe revisarse antes de cerrar la entrega; una prueba anterior correcta no convierte este intento en un éxito.

B15 | 15:20-16:30 PREVISTO

Pruebas, dependencias y repositorio

Requisitos: RNF-01, RNF-04, RNF-06, RE-03

PANTALLA - NO LEER

- Mostrar closeout-verification.json: backend99/0/0, clon limpio y navegador, vulnerabilidades0, Gitleaks y CI.

- Mostrar el README y el historial de commits de practica3.

- En este bloque muestra evidencia guardada; no digas que ejecutas99tests en directo. El comando pytest del anexo sirve para ensayar antes o para otra comprobación fuera del recorrido base.

- No mostrar una marca verde de Actions: el bloqueo de facturación sigue siendo una limitación registrada.

LEER

Esta es la evidencia guardada del cierre técnico, no una ejecución nueva de toda la suite. Registra noventa y nueve pruebas superadas: noventa y dos de aplicación y operaciones, y siete de validación de entrega.

También se comprobó una instalación desde un clon limpio de GitHub, con configuración y base nuevas, y cinco escenarios de navegador. Hay otros cinco escenarios remotos. Las auditorías de dependencias no detectaron vulnerabilidades conocidas en esa revisión.

Gitleaks revisó el historial disponible. Dos avisos iniciales se clasificaron como falsos positivos concretos y el escaneo final no dejó hallazgos accionables. Esto no garantiza ausencia total de vulnerabilidades.

GitHub Actions no llegó a ejecutar los trabajos por un bloqueo de facturación de la cuenta. Está documentado y no lo presento como CI superado. El repositorio conserva código editable, instalación, pruebas y commits separados.

B16 | 16:30-17:30 PREVISTO

Limitaciones, asistencia IA y cierre

Requisitos: RNF-05, RNF-07, RE-01, RE-02, RE-03

PANTALLA - NO LEER

- Mostrar la sección Limitaciones de la memoria y después volver al Dashboard.

- Leer solo la alternativa de prueba externa que sea cierta al grabar.

- No decir que ya existe tag final, enlace del vídeo o entrega al campus. Eso se cierra después de grabar.

- Al terminar, detener grabación y comprobar el archivo MP4 real: duración, resolución y sonido.

LEER

Para terminar, esta herramienta es un autodiagnóstico académico, no una auditoría, certificación ni garantía legal. Antes de venderla a hoteles quedarían correo real, MFA, copias externas cifradas, mantenimiento, monitorización y revisión independiente. El backup probado está en el mismo VPS: no protege frente a la pérdida completa del servidor.

He utilizado Codex como asistencia para revisar requisitos, implementar, diagnosticar, ejecutar pruebas y preparar documentación y este guion. Lo declaro en la memoria. La responsabilidad de comprender, revisar y defender el trabajo sigue siendo mía. Las cuarenta horas consignadas son mi estimación personal aproximada, no un registro auditado.

Estos límites quedan documentados.

DECIR antes de la despedida si todavía falta la prueba externa

Queda pendiente la instalación siguiendo el README por una persona ajena al grupo. La instalación automatizada limpia está comprobada, pero no la presento como si una persona externa ya la hubiera realizado.

DECIR antes de la despedida solo si ya hay un registro REAL de instalación externa

La prueba por una persona ajena al grupo está registrada con su fecha y resultado. Esa comprobación manual se diferencia de la instalación automatizada y se incorpora a la documentación de entrega.

LEER AL FINAL DEL BLOQUE

Después de grabar incorporaré el enlace y los minutos reales a la matriz. Revisaré la memoria y etiquetaré el commit definitivo antes de entregar. Gracias.

Comandos preparados

Solo sistemas propios. Sin llamadas IA de pago en estos comandos. No capturar secretos.

Seguridad en directo, sin IA

PowerShell local de VS Code; raíz del proyecto. Crea y borra dos cuentas ficticias propias. Ejecutar una vez. Copiar el comando completo del Markdown, incluidas sus tres líneas.

```
backend/.venv/Scripts/python.exe scripts/verify_deployment.py `
--url https://178-105-149-202.sslip.io `
--confirm-test-data
```

Pruebas unitarias opcionales

PowerShell local; raíz del proyecto. Usa bases temporales, no la DB de producción. La suite tiene un aviso conocido de deprecación; no confundirlo con fallo.

```
$env:PYTHONPATH="$PWD/backend"
backend/.venv/Scripts/python.exe -m pytest backend/tests -q
```

Consultar versión pública

Navegador: respuesta pública de salud, no revela clave ni datos de usuarios.

```
https://178-105-149-202.sslip.io/api/v1/health
```

Si algo no sale como esperabas

Una espera larga

La petición sigue en curso. Si elimino esta espera en la edición, indicaré el corte en pantalla; no lo utilizaré para ocultar un error.

Error inesperado

Este resultado no es el esperado y lo mantengo visible. No lo voy a presentar como una prueba superada. Tendré que revisar esta ejecución antes de cerrar la entrega.

429 o límite de uso

El servicio indica que se ha alcanzado un límite de peticiones. No voy a desactivarlo ni a repetir solicitudes continuamente. Espero a que corresponda o continúo por reglas, explicando la limitación.

Comparativa no visible

En esta ejecución no aparece la comparación. Su alcance está limitado a la página de historial cargada; revisaré que ambas evaluaciones sean del mismo alojamiento y estén disponibles. No voy a inventar una variación.

Error al registrar porque la cuenta existe

Esta cuenta ya se utilizó en el ensayo. Voy a acceder a ella o utilizar otra cuenta ficticia; no presentaré un acceso como si fuera un registro nuevo.

Despues de grabar

1. Reproducir el MP4 completo. Medir duración real >=10min, resolución >=720p, audio y legibilidad. Los tiempos del guion no prueban duración.

2. Si hay un error real pendiente en el producto, corregirlo o documentar la limitación antes de entregar. No editarlo para aparentar un éxito.

3. Subir como no listado o con acceso mediante enlace y comprobar desde incógnito. Anotar URL, duración, resolución y formato reales.

4. Rellenar los minutos MM:SS donde realmente se ve cada requisito. Algunos pueden compartir bloque; usar el punto exacto de tu vídeo, no el inicio previsto de esta hoja.

5. Confirmar grupo e instalación por persona externa. Entregar esos datos y el enlace para actualizar memoria_content.json, delivery_metadata.json y matriz.

6. Regenerar y revisar la memoria final, crear tag v1.0-practica3 sobre el commit definitivo y comprobar el acceso al repo. No se crea el tag por generar este guion.

7. Adjuntar PDF y enlaces a vídeo y GitHub en la tarea del campus y en portada. Confirmar la hora de cierre del16/10; el enunciado no fija aquí una hora que podamos inventar.

8. Después de grabar y conservar las evidencias necesarias, borrar solo la cuenta ficticia del vídeo y sus datos. No borrar tu cuenta personal ni ejecutar down-v.

Minutos REALES de tu video

Completar despues de revisar el MP4. Los bloques sirven para localizar el momento, no sustituyen el segundo real.

Requisito	Bloques orientativos	MM:SS real
RF-01	B05	Pendiente
RF-02	B07, B10	Pendiente
RF-03	B07	Pendiente
RF-04	B08, B12	Pendiente
RF-05	B08, B11	Pendiente
RF-06	B09, B11	Pendiente
RF-07	B07, B09	Pendiente
RF-08	B11	Pendiente
RF-09	B09, B10	Pendiente
RF-10	B10	Pendiente
RF-11	B04, B13, B14	Pendiente
RF-12	B06, B12	Pendiente
RF-13	B12	Pendiente
RNF-01	B03, B15	Pendiente
RNF-02	B05, B06, B14	Pendiente
RNF-03	B03, B14	Pendiente
RNF-04	B15	Pendiente
RNF-05	B04, B05, B13, B14, B16	Pendiente
RNF-06	B12, B15	Pendiente
RNF-07	B03, B16	Pendiente
RE-01	B01, B02, B16	Pendiente
RE-02	B01, B16	Pendiente
RE-03	B02, B03, B15, B16	Pendiente

Entiende lo que estas explicando

Concepto	Explicacion
Frontend	La pantalla y los controles que utiliza el usuario.
Backend / API	El servidor que valida peticiones, aplica reglas y guarda/recupera resultados.
Snapshot	Una evaluación guardada; una reevaluación crea otra sin sobrescribirla.
Argon2	Algoritmo de hash para contraseñas; no es cifrado reversible.
HttpOnly	La cookie no puede leerse desde JavaScript; no elimina todos los riesgos del navegador.
CSRF	Control que ayuda a rechazar cambios inducidos desde otro sitio. No sustituye comprobar propietario.
Fallback	Respaldo por reglas cuando no se usa o no responde correctamente la IA.
MFA	Autenticación con más de un factor; en el formulario describe al hotel, no una función MFA de la app.
Migración	Cambio versionado de tablas o índices mediante Alembic.
Cuota IA	Límite de peticiones, no un tope de dólares ni de llamadas internas.
PMS	Sistema de gestión del alojamiento; no hay integración real con un PMS en este proyecto.